

FDE-Associate Foundation — Governance, Risk & Responsible Use

35 Scenario-Based MCQs • Professional / Anthropic-Level Difficulty

Source: AI Agent Factory — Governance, Risk & Responsible Use: A Crash Course.

Verified distribution: 19 single-answer + 8 two-answer + 8 table-based = 35 questions.

1. A customer-support team wants an agent to draft billing-dispute replies from account records. The drafts are usually accurate, but an incorrect claim about a charge could create contractual and reputational consequences. The support agent can verify the record before sending, and the customer never receives the raw model output. Which governance classification is strongest?

- A. Fully appropriate because the task is only drafting.
- B. Appropriate with a defined human review gate before sending.
- C. Inappropriate because AI must never touch billing information.
- D. Fully appropriate if the model has a high benchmark score.

Answer: B

2. A team says its compliance control is: “A human will review every output.” In practice, no role is named, reviewers do not know what they must verify, and some reviews happen after reports are sent. An FDE is asked to make the workflow production-ready. What is the most important correction?

- A. Add a larger model and reduce hallucinations.
- B. Add a dashboard showing review completion.
- C. Define who checks what, and before which irreversible step.
- D. Require two humans to read every output.

Answer: C

3. A finance analyst wants spending trends across thousands of customer records. Names and account numbers are present, but the requested analysis only needs aggregate patterns. The approved AI route permits anonymized trend analysis but not raw regulated identifiers. What should the FDE recommend first?

- A. Upload the raw data but instruct the model not to retain it.
- B. Cancel the analysis because customer data is involved.
- C. Redact unnecessary identifiers, verify the remaining data cannot identify people, then use the approved route.
- D. Replace names with Customer 1, Customer 2 and treat the data as anonymous.

Answer: C

4. A project uses a connector that can read and write to a shared drive. The agent only needs to retrieve three reference files, but the team proposes keeping write access “in case we need it later.” The workflow has no automated write action. Which architecture best reflects least privilege?

- A. Keep read/write access because the connector is already approved.
- B. Use read-only access scoped to the required files or location.
- C. Give the agent admin access but add more prompt instructions.
- D. Disable audit logging to reduce operational complexity.

Answer: B

5. An FDE receives a Skill from a public forum that claims to summarize meeting notes. Its description is benign, but the package includes instructions that can invoke tools beyond summarization. The session in which it would run can access confidential project files. What is the best immediate decision?

- A. Enable it in production and monitor for one week.
- B. Trust it because a colleague reported good results.
- C. Escalate or decline because source and reach are unresolved and disproportionate.
- D. Enable it only for senior employees.

Answer: C

6. A trusted internal connector reads customer-uploaded documents and can also send emails. A malicious customer document contains instructions telling the agent to email a confidential file to an external address. The connector itself passed the organization's source review. What is the primary hidden failure mode?

- A. Model drift caused by the connector publisher.
- B. Prompt injection from untrusted content combined with consequential action authority.
- C. Insufficient storage retention controls.
- D. Excessive model temperature.

Answer: B

7. A hiring workflow uses AI to rank applicants, and reviewers inspect only the top 20 candidates because of time pressure. Several qualified applicants from one group appear to disappear before human review. The team argues that no adverse decision is made automatically. What control most directly addresses the risk?

- A. Increase the model context window.
- B. Review the inclusion and exclusion populations, including samples of rejected candidates.
- C. Remove all demographic fields from the prompt.
- D. Require the model to explain every ranking.

Answer: B

8. A meeting-notetaker is introduced for client calls. The summaries are useful, but participants are not told that the system records the conversation. The calls may contain customer information and commitments that later influence contracts. What is the strongest governance response?

- A. Keep it silent because the tool only creates notes.
- B. Announce the notetaker at the start and verify route, disclosure, and summary-review requirements.
- C. Disable memory and assume that resolves the issue.
- D. Ask the model to avoid recording sensitive sentences.

Answer: B

9. A team discovers that a confidential client document was accidentally pasted into an unapproved AI chat. The employee immediately considers deleting the conversation and saying nothing because "no output was shared." What should happen first?

- A. Delete the conversation and continue working.
- B. Wait to see whether the provider retained it.
- C. Stop further spread, record the facts, and report promptly through the incident path.
- D. Notify the client directly before telling internal stakeholders.

Answer: C

10. A production workflow has a Governance Record created six months ago. Since then, the model family changed, the connector gained a new send capability, and the customer population expanded. The workflow owner argues that the record is already approved. What is the correct response?

- A. Keep the record unchanged until the annual review.
- B. Re-check the relevant governance blocks because material workflow properties changed.
- C. Only update the monitoring owner.
- D. Re-approve the entire company AI policy.

Answer: B

11. An organization has no formal AI policy for a proposed customer-reporting workflow. The business asks the FDE to write a document and label it "approved policy" so implementation can proceed. The FDE has no authority over legal, security, or privacy decisions. What should the FDE produce?

- A. An official-looking policy and sign it as project owner.
- B. A temporary technical exception that bypasses review.
- C. An interim proposal identifying assumptions, controls, owners, and questions for the proper policy owner.
- D. No documentation until the organization creates a policy.

Answer: C

12. A model produces an accurate-looking performance-review draft for an employee. The manager checks each sentence against notes, but nobody compares the treatment of employees across the whole team. The workflow may systematically describe one group more harshly. What additional control is most valuable?

- A. Increase sampling temperature.
- B. Compare outputs across employees for consistency and potential disparate framing.
- C. Remove the employee's name from the prompt.
- D. Require the model to produce citations.

Answer: B

13. An FDE is evaluating whether a high-consequence workflow can use AI. The task can be reversed before execution, a qualified reviewer can check the output before action, and accountability remains with that reviewer. The team is debating whether high consequence alone makes AI use prohibited. Which principle applies?

- A. High consequence always means inappropriate.
- B. Low consequence always means fully appropriate.
- C. High consequence can be appropriate with a well-designed, pre-action human gate.
- D. Human review transfers accountability to the AI system.

Answer: C

14. A data scientist replaces employee names with stable IDs before analysis, but the HR team retains a lookup table connecting each ID to a person. The analyst argues the dataset is now anonymous and can be moved to a less restricted route. What is the correct classification?

- A. Anonymous because names were removed.
- B. Pseudonymized, because re-identification remains possible.
- C. Public because the IDs have no semantic meaning.
- D. Synthetic because the values are transformed.

Answer: B

15. A connector is approved for reading a reporting database. During a pilot, an engineer discovers that the same credential can also update records even though the workflow never needs writes. The connector owner says the write capability is harmless because the agent has not used it yet. What should the FDE do?

- A. Leave it unchanged and rely on prompt instructions.
- B. Narrow the permission to read-only access if technically possible.
- C. Add a warning in the system prompt and keep the privilege.
- D. Remove all database access from the project.

Answer: B

16. A team notices that users repeatedly bypass the approved AI route because it takes ten steps, while an unapproved tool takes one. Management proposes banning all AI tools to eliminate shadow AI. The FDE instead wants to reduce the behavior that is creating the risk. Which intervention best matches the course's friction rule?

- A. Make the approved route easier while preserving its required controls.
- B. Increase penalties for every employee who uses an unapproved tool.
- C. Remove audit logging from the approved route.
- D. Allow the unapproved tool for low-risk tasks without review.

Answer: A

17. A governance audit finds that three users skipped a review gate during deadline pressure. The manager wants the audit report to identify and discipline those employees. The FDE suspects the approved workflow is slow and unclear. What is the better governance approach?

- A. Audit the process for friction, weak gates, stale permissions, and confusing rules.
- B. Avoid auditing the workflow because discipline is more important.
- C. Remove the human gate so users stop bypassing it.
- D. Require employees to sign a daily compliance statement.

Answer: A

18. A customer-facing AI workflow has passed all planned controls: data route approved, human review enforced, permissions scoped, and monitoring active. However, a subtle wording bias may consistently disadvantage one customer segment without causing obvious factual errors. How should this be represented?

- A. As zero risk because every control passed.
- B. As residual risk requiring monitoring and possibly comparative sampling.
- C. As a data-tier failure only.
- D. As a prompt-injection incident.

Answer: B

19. A team wants to automate a task that sends refunds. The model reads customer emails and proposes the refund amount. The agent has permission to execute the refund immediately, and the team argues that its benchmark accuracy is 99%. What is the strongest design change?

- A. Keep automatic execution because 99% accuracy is sufficient.
- B. Put the irreversible refund action behind a defined human gate until the workflow earns more autonomy.
- C. Increase model temperature to expose uncertainty.
- D. Allow execution only when the email contains no attachments.

Answer: B

20. A support workflow drafts responses from customer records and external attachments. The organization wants to reduce risk without abandoning useful automation. Which TWO controls most directly align with the governance framework? **[Select exactly TWO]**

- A. Use the minimum data needed for the task.
- B. Allow the agent to send replies automatically after a high benchmark score.
- C. Define a reviewer, verification target, and pre-send review point.
- D. Assume attachments are trusted because the connector is approved.
- E. Disable all logging to protect customer privacy.

Correct answers: A and C

21. A team is reviewing a third-party Skill before enabling it in a session that can access confidential files. Which TWO findings should most strongly push the decision toward escalation rather than immediate enablement? **[Select exactly TWO]**

- A. The package has a clear publisher and only performs formatting.
- B. The Skill's actual instructions request broader tool access than its stated purpose.
- C. The source is unknown and the package contains scripts with external-service access.
- D. The Skill is popular with other users.
- E. The Skill has been scanned and the scanner reports no obvious malicious content.

Correct answers: B and C

22. An AI workflow ranks applications for human review. The team wants evidence that the workflow is not systematically excluding qualified people. Which TWO actions are most appropriate? **[Select exactly TWO]**

- A. Inspect only the final top-ranked set.
- B. Sample excluded applicants as well as included applicants.
- C. Compare inclusion/exclusion patterns across relevant groups.
- D. Remove all review because humans are already involved.
- E. Optimize only for overall ranking accuracy.

Correct answers: B and C

23. A sensitive dataset is needed for a trend analysis, but the task does not require direct identifiers. Which TWO steps are strongest before the data enters the AI route? **[Select exactly TWO]**

- A. Remove fields the task does not need.
- B. Replace names with labels and automatically call the result anonymous.
- C. Verify that remaining combinations cannot identify people under the applicable standard.
- D. Upload the raw data in an incognito mode.
- E. Tell the model not to retain the data.

Correct answers: A and C

24. An AI incident has just been discovered: a tool may have sent confidential material to an external recipient. Which TWO actions belong in the first-hour response? **[Select exactly TWO]**

- A. Delete every copy you can find before reporting.
- B. Stop unnecessary further spread and preserve the facts.
- C. Report promptly through the organization's incident path.
- D. Notify the external recipient yourself before the incident owner investigates.
- E. Wait until the full root cause is proven.

Correct answers: B and C

25. A Governance Record has become stale after a workflow expansion. Which TWO changes are explicit triggers for re-checking governance? **[Select exactly TWO]**

- A. The model or model family changes.
- B. The team changes its logo.
- C. The audience or affected population changes.
- D. The owner prints a new copy of the record.
- E. The same prompt is used one additional time.

Correct answers: A and C

26. A team wants to deploy an agent with access to external web pages and a payment tool. Which TWO design choices best reduce prompt-injection consequences? **[Select exactly TWO]**

- A. Give the agent read-only access wherever possible.
- B. Let web content directly trigger payment actions.
- C. Keep pay/send/delete/approve actions behind a defined gate.
- D. Trust all content because the browser tool is internally published.
- E. Increase the model context window.

Correct answers: A and C

27. An organization finds repeated shadow-AI use among a team under deadline pressure. Which TWO responses best address the systemic cause rather than only the individual behavior? **[Select exactly TWO]**

- A. Audit which approved steps create unnecessary friction.
- B. Remove all approved AI tools.
- C. Make the approved route easier while preserving necessary controls.
- D. Publicly identify repeat users as a deterrent.
- E. Ignore low-volume shadow use.

Correct answers: A and C

28. A logistics customer-reporting agent produces weekly service-exception reports. The FDE is deciding whether each control is strong enough for production. The report is generated from dispatch data, reviewed by an account manager, and then sent to a customer. Use the table to identify the strongest governance classification. **[Table-based]**

Dimension	Observed state	Risk	Control	Evidence
Case	Draft is reviewed before sending	Customer contracts may be affected	Account manager verifies facts/tone	Review completion is logged
Data	Only required dispatch fields are used	Some employee/customer details remain	Approved route + minimization	Monthly sample
Capability	Read-only dispatch connector	No write action needed	Scoped read access	Permission audit
People	Drivers and customers can be affected	Attribution may shift blame	Compare phrasing and facts	Cross-report sample

- A. Fully appropriate with no special gate
- B. Appropriate with review because accountability and customer impact remain
- C. Inappropriate because any AI use in logistics is prohibited
- D. Fully appropriate because the connector is read-only

Answer: B

29. A team wants to use pseudonymized employee data for an AI trend analysis. The table shows what remains after transformation. Which row creates the decisive reason the data cannot simply be treated as anonymous? **[Table-based]**

Test	Result	Interpretation	Implication
Names removed	Yes	Direct identifiers removed	Necessary but insufficient
Stable IDs	Yes	Same person keeps same label	Supports linkage
Lookup table	Held by HR	IDs can be mapped to employees	Re-identification remains possible
Purpose	Trend analysis	Does not need identity	Redaction may be possible

- A. Names were removed
- B. Stable IDs were used
- C. HR retains the lookup table
- D. Trend analysis does not need names

Answer: C

30. An agent uses a trusted connector to read external customer documents and can also send email. The FDE maps the workflow as follows. Which row identifies the highest-risk interaction? **[Table-based]**

Element	Publisher/content	Access	Action	Risk
Connector	Trusted internal team	Read customer docs	None	Low
Customer PDF	External/untrusted	Read by agent	None	Prompt injection possible
Customer PDF + email	External/untrusted	Read by agent	Send email	Injection can become consequential
Internal FAQ	Trusted	Read-only	None	Low

- A. Trusted connector + internal FAQ
- B. Customer PDF read-only
- C. Customer PDF combined with email-send authority
- D. Internal connector source review

Answer: C

31. A hiring workflow uses AI to produce a shortlist. The team wants to know whether its human review is sufficient. Which evidence row most strongly exposes the hidden fairness failure? **[Table-based]**

Metric	Included candidates	Excluded candidates	Review behavior	Signal
Overall accuracy	High	Not measured	Review survivors only	Incomplete
Group A	48%	52%	Sampled	Moderate
Group B	62%	38%	Sampled	Moderate
Group C	95%	5%	Not sampled	Potential blind spot

- A. Overall accuracy
- B. Group A inclusion rate
- C. Group B inclusion rate
- D. Group C has no exclusion review despite high inclusion

Answer: D

32. A team reports an accidental upload of confidential material to an unapproved route. The incident owner has not yet responded. Which first-hour action sequence is best supported by the table? **[Table-based]**

Step	Proposed action	Effect	Governance value
1	Delete the chat	May remove local visibility	Weak / potentially harmful
2	Stop further sharing	Limits spread	Strong
3	Record route, data, time, onward sharing	Preserves facts	Strong
4	Wait for root cause	Delays reporting	Weak
5	Report through incident path	Starts formal handling	Strong

- A. 1 → 4 → 5
- B. 2 → 3 → 5
- C. 3 → 1 → 4

D. 1 → 2 → 4

Answer: B

33. An FDE is deciding whether a connector should be enabled. The table captures the capability review. Which outcome is most defensible? **[Table-based]**

Check	Finding	Assessment	Needed action
Source	Internal platform team	Known	Verify current owner
Reach	Read + write shared drive	Broader than task	Narrow scope
Fit	Task only needs retrieval	Write unnecessary	Prefer read-only
Outside content	Vendor documents	Untrusted content possible	Add injection-aware controls
Actions	No send/delete	Limited consequence	Retain human gate for future writes

- A. Enable unchanged
- B. Decline automatically because vendor documents exist
- C. Escalate with a specific request to narrow write access and assess external-content risk
- D. Enable and observe for a month

Answer: C

34. A Governance Record is reviewed before a major release. The table shows what changed since the last approval. Which item most clearly requires re-checking the relevant governance block? **[Table-based]**

Dimension	Previous	Current	Change significance
Model	Model X	Model X	None
Connector	Read-only	Read-only	None
Audience	Internal ops	External customers	Material
Data	Same fields	Same fields	None
Policy	Same	Same	None

- A. Model
- B. Connector
- C. Audience
- D. Data

Answer: C

35. A production AI workflow has all planned controls operating correctly, but a subtle systematic issue remains. The table is used to classify the remaining exposure. **[Table-based]**

Control	Status	Observed effect	Residual concern
Human gate	Working	Factual errors caught	Bias in phrasing may survive
Data minimization	Working	Less sensitive data	No direct fairness control
Scoped access	Working	No unintended writes	Does not assess wording
Monthly sample	Working	Checks individual reports	Cross-group comparison may be needed

- A. There is no remaining risk
- B. The workflow is a security incident
- C. The remaining concern is residual risk requiring comparative monitoring
- D. Data minimization failed

Answer: C

Exam design principle: classify before acting; when the answer is in the middle, name the commitment and write down why.